UNIVERSIDAD PRIVADA DOMINGO SAVIO

ACTIVIDAD 3: AUTENTICACIÓN, SEGURIDAD, TRANSACCIONES Y REPORTES SISTEMA WEB DE LA ASOCIACIÓN DE APICULTORES “FLOR DE LA CHIQUITANÍA”.

Carrera: Ingeniería de Sistemas

Asignatura: Tecnología Web II

Docente: M.Sc. Ing. Jimmy Nataniel Requena Llorentty

Integrantes:

Alejandro Fabián Cabrera Flores

María Alejandra Suárez O.

Jade Guissel Flores Coria

Ariel Salas Tococari

Renzo Molina Navia

Santa Cruz de la Sierra - octubre 2026

ÍNDICE

RESUMEN 3
ABSTRACT 3
INTRODUCCIÓN 4
OBJETIVOS 4
Objetivo general 4
Objetivos específicos 4
ALCANCE Y METODOLOGÍA 4
DESCRIPCIÓN DEL SISTEMA Y ARQUITECTURA 5
1. LABORATORIO 10: AUTENTICACIÓN Y SEGURIDAD 6
1.1. Gestión de usuarios y contraseñas 6
1.2. Sesiones seguras 6
1.3. Protección CSRF y XSS 7
1.4. Permisos por rol 9
1.5. Pruebas documentadas del Laboratorio 10 10
2. LABORATORIO 11: ACOPIOS, VENTAS Y REPORTES 12
2.1. Registro transaccional de acopios 12
2.2. Registro transaccional de ventas 12
2.3. Reportes SQL 13
2.4. Exportación CSV segura 15
2.5. Resultados documentados del Laboratorio 11 16
3. Resultados generales 17
CONCLUSIONES 18
RECOMENDACIONES 19
REFERENCIAS 20

RESUMEN

El presente informe documenta la ampliación del sistema web de la Asociación de Apicultores “Flor de la Chiquitanía” mediante los laboratorios 10 y 11 de Tecnología Web II. El Laboratorio 10 aborda autenticación, gestión segura de sesiones, autorización por roles y defensas frente a ataques habituales en formularios web. El Laboratorio 11 incorpora el registro transaccional de acopios y ventas, actualización consistente del inventario, consultas SQL para reportes y exportación de resultados a CSV. Las bitácoras proporcionadas registran 15 de 15 comprobaciones satisfactorias en cada laboratorio. Entre las pruebas documentadas se incluyen la denegación de acciones no autorizadas, el rechazo de ventas sin stock, la conservación de la atomicidad, la validación estricta de fechas y la protección de celdas CSV frente a fórmulas

Palabras clave: *autenticación, autorización, CSRF, transacciones, inventario, reportes SQL, CSV.*

ABSTRACT

This report documents the enhancement of the web-based system for the “Flor de la Chiquitanía” Beekeepers Association through Laboratories 10 and 11 of the Web Technology II course. Laboratory 10 focuses on authentication, secure session management, role-based authorization, and protection against common attacks on web forms. Laboratory 11 incorporates transactional recording of honey collection and sales, consistent inventory updates, SQL queries for reporting, and CSV data export. The provided AI logs record 15 out of 15 successful checks for each laboratory. The documented tests include the denial of unauthorized actions, the rejection of sales when stock is insufficient, the preservation of transaction atomicity, strict date validation, and protection against spreadsheet formula injection in CSV files.

Keywords: *authentication, authorization, CSRF, transactions, inventory, SQL reports, CSV.*

INTRODUCCIÓN

Un sistema de gestión de una asociación apícola necesita controlar quién puede consultar y modificar la información, mantener la consistencia del inventario y facilitar reportes que apoyen las decisiones administrativas. En una aplicación que registra productos, socios, acopios y ventas, los errores de autorización o las actualizaciones parciales pueden comprometer la confidencialidad y la integridad de los datos.

La Actividad 3 integra dos objetivos complementarios. El Laboratorio 10 incorpora autenticación y controles de seguridad; el Laboratorio 11 aplica transacciones a los movimientos de inventario y genera reportes agrupados exportables.

OBJETIVOS

Objetivo general

Agregar autenticación con roles, operaciones transaccionales y reportes al sistema web de la asociación, demostrando que cada tipo de usuario puede acceder únicamente a las funciones que le corresponden.

Objetivos específicos

- Implementar almacenamiento de contraseñas mediante password_hash() y verificación con password_verify().
- Aplicar regeneración y configuración segura de sesiones, control de intentos fallidos, tokens CSRF y escape de salida contra XSS.
- Restringir en el servidor las operaciones según los roles administrador, operador y socio.
- Registrar acopios y ventas de manera transaccional, actualizando el stock sin dejar cambios parciales.
- Construir reportes con JOIN, GROUP BY, HAVING y LEFT JOIN, y permitir su exportación segura a CSV.
- Verificar los resultados mediante el verificador automatizado y pruebas funcionales con distintos roles.

ALCANCE Y METODOLOGÍA

El alcance comprende los laboratorios 10 y 11 del sistema de la asociación. Se revisaron la guía integral, las bitácoras de IA y la descripción disponible del paquete de prácticas. La

metodología consistió en organizar los requisitos, relacionarlos con los componentes del código y resumir las correcciones y pruebas registradas.

DESCRIPCIÓN DEL SISTEMA Y ARQUITECTURA

La aplicación “Apicultores Flor de la Chiquitanía” administra productos vinculados a socios, movimientos de acopio y ventas. La estructura descrita separa responsabilidades entre controladores, repositorios, componentes de seguridad, servicios de movimientos, reportes, plantillas y scripts SQL. PHP implementa la lógica de la aplicación; PDO gestiona el acceso a MySQL mediante consultas preparadas y Docker Compose facilita la ejecución de la base de datos.

El sistema se organiza en componentes que separan autenticación, gestión de datos, movimientos de inventario y generación de reportes. Como se presenta en la Tabla 1, cada componente cumple una función específica dentro de la aplicación.

Tabla 1

Componentes principales del sistema

Componente	Responsabilidad documentada
Autenticación y sesiones	Validar credenciales, gestionar sesión, regenerar el identificador y cerrar sesión.
Roles y permisos	Autorizar o denegar operaciones de administrador, operador y socio en el servidor.
Repositorio de productos y socios	Consultar y persistir datos mediante PDO y sentencias preparadas.
Registro de acopios	Guardar el movimiento recibido y aumentar el stock dentro de una transacción.
Registro de ventas	Validar stock, guardar cabecera y detalles, conservar precio histórico y descontar inventario de forma atómica.
Reportes	Calcular ventas por mes, productos más vendidos, importes por socio y productos sin ventas.
Exportación CSV	Generar un archivo UTF-8 separado por punto y coma y neutralizar contenido que pueda interpretarse como fórmula.

1. LABORATORIO 10: AUTENTICACIÓN Y SEGURIDAD

1.1. Gestión de usuarios y contraseñas

La tabla usuarios contempla identificador, nombre, correo único, hash de contraseña, rol, asociación opcional con un socio, contador de intentos fallidos y fecha de bloqueo. Las contraseñas se almacenan como hash con password_hash() y se validan con password_verify() (PHP Documentation Group, s. f.); no se guarda la contraseña en texto plano. La guía también plantea password_needs_rehash() para actualizar hashes que utilicen parámetros antiguos (Tecnología Web II, 2026a).

El registro público no debe permitir que una persona se asigne el rol administrador u operador. La asignación de roles privilegiados debe realizarse mediante un proceso administrativo autorizado. Las consultas de autenticación se ejecutan con PDO y sentencias preparadas.

Figura 1

Verificación segura de contraseñas

src/Seguridad/Autenticador.php

```
35          if (!password_verify($clave, $fila['clave_hash'])) {
36              $this->usuarios->registrarFallo((int) $fila['id'], self::MAXIMO_INTENTOS, self::BLOQUEO_SEGUNDOS);
37              return null;
38          }
39
40          $this->usuarios->registrarExito((int) $fila['id']);
41
42          if (password_needs_rehash($fila['clave_hash'], PASSWORD_DEFAULT, self::OPCIONES_HASH)) {
43              $nuevoHash = password_hash($clave, PASSWORD_DEFAULT, self::OPCIONES_HASH);
44              $this->usuarios->actualizarHash((int) $fila['id'], $nuevoHash);
45          }
```

Nota. Fragmento de elaboración propia a partir del código fuente del proyecto: src/Seguridad/Autenticador.php (líneas 35–45).

1.2. Sesiones seguras

Después de validar las credenciales, la sesión debe regenerar su identificador mediante session_regenerate_id(true). La configuración indicada en la guía utiliza modo estricto, cookie HttpOnly y SameSite=Lax; el atributo Secure debe activarse en un entorno HTTPS (Tecnología Web II, 2026a). La sesión guarda únicamente los datos necesarios y la aplicación aplica expiración por inactividad de 1.800 segundos y destrucción al cerrar sesión.

Figura 2

Configuración y regeneración de sesiones

src/Seguridad/Sesion.php

```
25          ini_set('session.use_strict_mode', '1');
26          ini_set('session.use_only_cookies', '1');
27
28          session_name(self::NOMBRE);
29
30          session_set_cookie_params([
31              'lifetime' => 0,
32              'path' => '/',
33              'secure' => $https,
34              'httponly' => true,
35              'samesite' => 'Lax',
36          ]);
37
38          session_start();
    ...
62          // Evitar reutilizar el identificador previo al inicio de sesión.
63          if (!session_regenerate_id(true)) {
64              throw new \RuntimeException(
65                  'No se pudo regenerar el identificador de sesión.'
66              );
67          }
```

Nota. Fragmento de elaboración propia a partir del código fuente del proyecto: src/Seguridad/Sesion.php (líneas 25–38 y 62–67).

1.3. Protección CSRF y XSS

Los formularios que cambian el estado de la aplicación incluyen un token CSRF. El servidor compara el token recibido con el almacenado en la sesión usando hash_equals(); un token ausente o incorrecto debe producir una denegación HTTP 403 (OWASP Foundation, s. f.-a). Los valores dinámicos que se muestran en HTML se escapan con htmlspecialchars() para evitar que contenido introducido por usuarios se interprete como marcado o JavaScript.

Figura 3

Validación del token CSRF

plantillas/entrar.php

```
 4 <form method="post" action="/entrar">
 5   <input type="hidden" name="_csrf" value="<?= $csrf ?>">
```

src/Seguridad/Csrf.php

```
27     public static function validar(?string $token): void
28     {
29         Sesion::iniciar();
30
31         $esperado = $_SESSION[self::CAMPO] ?? null;
32
33         if (
34             !is_string($esperado) ||
35             strlen($esperado) !== 64 ||
36             !is_string($token) ||
37             !hash_equals($esperado, $token)
38         ) {
39             throw new Prohibido('Token CSRF inválido o ausente.');
40         }
41     }
```

Nota. Fragmento de elaboración propia a partir del código fuente del proyecto: plantillas/entrar.php (líneas 4–5) y src/Seguridad/Csrf.php (líneas 27–41).

Figura 4

Escape de salida contra XSS

src/funciones.php

```
 5 function e(string $texto): string
 6 {
 7     return htmlspecialchars(
 8     $texto,
 9     ENT_QUOTES | ENT_SUBSTITUTE,
10     'UTF-8'
11 );
12 }
```

src/Vista/Plantilla.php

```
49     /** Escapa recursivamente los textos; los números y booleanos pasan igual; Crudo pasa sin tocar. */
50     public static function escapar(mixed $valor): mixed
51     {
52         return match (true) {
53             is_string($valor) => htmlspecialchars(
54     $valor,
55     ENT_QUOTES | ENT_SUBSTITUTE,
56     'UTF-8'
57 ),
58             is_array($valor) => array_map(self::escapar(...), $valor),
```

Nota. Fragmento de elaboración propia a partir del código fuente del proyecto: src/funciones.php (líneas 5–12) y src/Vista/Plantilla.php (líneas 49–58).

1.4. Permisos por rol

Para garantizar que cada usuario acceda únicamente a las funciones autorizadas, se estableció una matriz de permisos. La Tabla 2 resume las operaciones permitidas y restringidas para cada rol, incluyendo administración de productos, registro de movimientos y acceso a reportes.

Tabla 2

Matriz de permisos por rol

Acción	Administrador	Operador	Socio
Iniciar sesión	Permitido	Permitido	Permitido
Ver productos	Todos	Todos	Solo propios
Crear o editar productos	Permitido	Permitido	Denegado
Eliminar productos	Permitido	Denegado	Denegado
Ver socios	Permitido	Permitido	Denegado
Registrar ventas y acopios	Permitido	Permitido	Denegado
Ver reportes generales	Permitido	Denegado	Denegado
Exportar CSV	Permitido	Denegado	Denegado

La autorización se verifica en las rutas y operaciones del servidor; ocultar un botón no constituye una medida suficiente. Para el rol socio, la consulta debe limitar los productos asociados al socio autenticado.

Figura 5

Control de acceso según el rol

src/Modelo/Rol.php

```php
    public function puede(string $accion): bool
    {
        return match ($this) {
            self::Admin => in_array($accion, [
                'productos.ver', 'productos.crear', 'productos.editar', 'productos.eliminar',
                'socios.ver', 'socios.crear', 'socios.editar', 'socios.eliminar'
            ], true),
            self::Operador => in_array($accion, [
                'productos.ver', 'productos.crear', 'productos.editar',
                'socios.ver'
            ], true),
            self::Socio => in_array($accion, [
                'productos.ver'
            ], true),
        };
    }
```

src/Controladores/ProductosControlador.php

```php
    /** Autorización: cada acción pregunta a la matriz de permisos del rol. */
    private function autorizar(string $accion): void
    {
        if (!$this->usuario->puede($accion)) {
            throw new Prohibido('Tu rol (' . $this->usuario->rol->etiqueta() . ') no permite esta acción.');
        }
    }
```

Nota. Fragmento de elaboración propia a partir del código fuente del proyecto: src/Modelo/Rol.php (líneas 22–37) y src/Controladores/ProductosControlador.php (líneas 31–37).

1.5. Pruebas documentadas del Laboratorio 10

La bitácora de IA del Laboratorio 10 registra 15 de 15 comprobaciones. Entre ellas se incluyen hashes protegidos, autenticación, regeneración de sesión, permisos por rol, CSRF, cabeceras de seguridad y bloqueo tras intentos fallidos. También se documenta una corrección en ProductoRepositorioMysql.php: se cambiaron parámetros repetidos de una consulta preparada por nombres únicos, ya que el operador tenía permiso para editar, pero la operación fallaba por un problema de ejecución SQL (Salas Tococari, 2026a).



```
PS C:\Users\aRIEL> cd C:\TW2\recuperacion\lab10\inicio
PS C:\TW2\recuperacion\lab10\inicio> php .\verificar.php
[OK] Contraseñas guardadas con password_hash (bcrypt), nunca en texto
[OK] Matriz de permisos: operador edita pero no elimina; socio solo ve; acción desconocida → no
[OK] Sin sesión: /productos → 302 a /entrar?volver=… (recuerda adónde ibas)
[OK] Cabeceras de seguridad: CSP, nosniff, Referrer-Policy, sin X-Powered-By
[OK] Cookie de sesión: nombre propio, HttpOnly y SameSite=Lax
[OK] Contraseña errónea y correo inexistente → 401 con EL MISMO mensaje
[OK] Iniciar sesión sin token CSRF → 403
[OK] Ingreso correcto → 303 y ID de sesión NUEVO (session_regenerate_id)
[OK] Admin: elimina con token (303); sin token o con token falso → 403
[OK] Cerrar sesión (POST con token) → luego /productos vuelve a pedir ingreso
[OK] Operador: el hash cost 10 se actualiza a cost 12 al ingresar (password_needs_rehash)
[OK] Operador: edita (303) pero eliminar → 403 y no ve el botón Eliminar
[OK] Socio (Elena): ve SOLO sus 4 productos; registrar y ver socios → 403
[OK] 5 intentos fallidos bloquean la cuenta: el 6.°, aun correcto, → 429 con Retry-After
[OK] Redirección abierta bloqueada: volver=//sitio-malo.com → /productos
Resultado: 15 de 15 comprobaciones
PS C:\TW2\recuperacion\lab10\inicio>
```

Evidencia L10-01. Salida de php verificar.php del Laboratorio 10: 15 de 15 comprobaciones (incluye las pruebas de permisos del operador y del socio).



Evidencia L10-02a. Formulario de inicio de sesión (usuario con rol socio; la contraseña aparece oculta).



Evidencia L10-02b. Acceso denegado (HTTP 403) al intentar un socio abrir /productos/nuevo.

2. LABORATORIO 11: ACOPIOS, VENTAS Y REPORTES

2.1. Registro transaccional de acopios

El registro de un acopio valida que la cantidad y el importe sean positivos, localiza el producto y bloquea la fila correspondiente con SELECT ... FOR UPDATE. Luego inserta el movimiento en acopios e incrementa el stock. Ambas acciones se confirman con commit(); si ocurre una excepción, se ejecuta rollBack(), según el control de transacciones de MySQL (Oracle Corporation, s. f.). De este modo, el movimiento y el inventario se mantienen consistentes.

2.2. Registro transaccional de ventas

Una venta puede incluir varios productos. El proceso inicia una transacción, comprueba cada producto y descuenta stock solo si existe cantidad suficiente. La actualización condicional incorpora la condición stock >= cantidad y se verifica rowCount(); si no se actualiza una fila, se genera un conflicto por stock insuficiente. La cabecera de venta, los detalles, los precios unitarios históricos y los descuentos se confirman en una sola transacción.

La atomicidad significa que una venta se guarda por completo o no se guarda. Si una línea falla, el rollback evita que se conserve el descuento de otros productos. La bitácora reporta una prueba intentando vender 99 unidades de CER-1K, que generó un error controlado, y una prueba donde una línea fallida no descontó el stock de otra. También registra una corrección de PDO

SQLSTATE[HY093] por reutilizar un parámetro nombrado en una consulta UPDATE (Salas Tococari, 2026b).

Figura 6

Transacción para registrar ventas

src/Ventas/RegistroVenta.php

```
23          $this->bd->beginTransaction();
24
25          try {
26              // Usamos nombres únicos para evitar el error HY093
27              $buscar = $this->bd->prepare('SELECT id, precio FROM productos WHERE codigo = :codigo');
28
29              // Parámetros únicos para el UPDATE
30              $descontar = $this->bd->prepare('UPDATE productos SET stock = stock - :cant1 WHERE id = :id AND stock >= :cant2');
    ...
35              foreach ($lineas as $codigo => $cantidad) {
36                  $buscar->execute(['codigo' => $codigo]);
37                  $p = $buscar->fetch() ?: throw new DatosInvalidos(['general' => "No existe el producto $codigo."]);
38
39                  $descontar->execute([
40                      'cant1' => $cantidad,
41                      'id' => $p['id'],
42                      'cant2' => $cantidad
43                  ]);
44
45                  if ($descontar->rowCount() === 0) {
46                      throw new Conflicto("Stock insuficiente de $codigo para vender $cantidad.");
47                  }
    ...
68              $this->bd->commit();
69              return $ventaId;
70
71          } catch (Throwable $e) {
72              if ($this->bd->inTransaction()) {
73                  $this->bd->rollBack();
74              }
75              throw $e;
76          }
```

Nota. Fragmento de elaboración propia a partir del código fuente del proyecto: src/Ventas/RegistroVenta.php (líneas 23–30, 35–47 y 68–76).

2.3. Reportes SQL

Los reportes permiten analizar las ventas y el comportamiento del inventario mediante consultas SQL de agrupación y combinación de tablas. En la Tabla 3 se resumen las técnicas documentadas para obtener los resultados, como JOIN, GROUP BY, HAVING y LEFT JOIN.

Tabla 3

Consultas y técnicas utilizadas en los reportes SQL

Reporte	Técnica y finalidad
Ventas por mes	DATE_FORMAT, COUNT, SUM y GROUP BY para resumir cantidad de ventas e importe mensual.

Reporte	Técnica y finalidad
Cinco productos principales	JOIN entre ventas, detalle y productos; SUM de unidades e importe; ORDER BY y LIMIT.
Ventas asociadas a socios	JOIN con socios y productos, agrupación por socio y HAVING para filtrar importes mínimos.
Productos sin ventas	LEFT JOIN y filtro IS NULL para identificar productos sin movimientos de venta.
Período de fechas	Límite inferior inclusivo y límite superior exclusivo al día siguiente para incluir el último día completo.

Figura 7

Consultas SQL para reportes

src/Reportes/ReporteVentas.php

```
20      public function porMes(DateTimeImmutable $desde, DateTimeImmutable $hasta): array
21      {
22          $c = $this->bd->prepare(
23              'SELECT DATE_FORMAT(fecha, \'%Y-%m\') AS mes, COUNT(*) AS ventas, SUM(total) AS total
24               FROM ventas
25               WHERE fecha >= :desde AND fecha < :hasta
26               GROUP BY mes
27               ORDER BY mes ASC'
28          );
29          $c->execute($this->periodo($desde, $hasta));
30          return $c->fetchAll();
31      }
    ...
33      public function topProductos(DateTimeImmutable $desde, DateTimeImmutable $hasta, int $limite = 5): array
34      {
35          $c = $this->bd->prepare(
36              'SELECT p.codigo, p.nombre, SUM(d.cantidad) AS unidades, SUM(d.cantidad * d.precio_unitario) AS importe
37               FROM venta_detalle d
38               JOIN ventas v    ON v.id = d.venta_id
39               JOIN productos p ON p.id = d.producto_id
40               WHERE v.fecha >= :desde AND v.fecha < :hasta
41               GROUP BY p.id, p.codigo, p.nombre
42               ORDER BY importe DESC, p.codigo ASC
43               LIMIT :limite'
44          );
45
46          // SOLUCIÓN AL HY093: Pasamos todos los parámetros juntos en el execute.
47          // El límite debe ser forzosamente un entero.
48          $parametros = $this->periodo($desde, $hasta);
49          $parametros['limite'] = $limite;
50
51          $c->execute($parametros);
52          return $c->fetchAll();
53      }
```

Nota. Fragmento de elaboración propia a partir del código fuente del proyecto: src/Reportes/ReporteVentas.php (líneas 20–31 y 33–53).

En la consulta de los cinco productos principales, el código también corrige un error HY093 al pasar todos los parámetros, con el límite como entero, juntos en un único execute().

La validación de fechas debe rechazar formatos inválidos y fechas imposibles, como 2026-02-31, así como rangos en los que la fecha inicial sea posterior a la final. La bitácora documenta una comparación entre la fecha formateada y el texto original, aplicada en MovimientosControlador.php, y el resultado HTTP 422 para fechas inválidas.

2.4. Exportación CSV segura

El archivo CSV se genera con codificación UTF-8 y BOM, separador punto y coma y encabezados apropiados para abrirse en Excel con configuración regional en español. La función celdaSegura neutraliza, anteponiendo un apóstrofo, los textos que comienzan con =, +, - o @ (también tabulador o retorno de carro) para evitar que una hoja de cálculo los interprete como fórmulas (OWASP Foundation, s. f.-b). También se documenta la conversión de punto decimal a coma en valores decimales.

Figura 8

Exportación segura de reportes CSV

src/Reportes/Csv.php

```
13          fwrite($flujo, "\xEF\xBB\xBF");                        // BOM: Excel reconoce UTF-8 (tildes y ñ)
14          fputcsv($flujo, $encabezados, ';', '"', '');
15          foreach ($filas as $fila) {
16              // Escapamos las celdas antes de pasarlas a fputcsv
17              fputcsv($flujo, array_map(self::celdaSegura(...), array_values($fila)), ';', '"', '');
    ...
27      public static function celdaSegura(mixed $valor): string
28      {
29          // 1. Manejo de números decimales (flotantes o strings tipo "123.45")
30          if (is_float($valor) || (is_string($valor) && preg_match('/^-?\d+\.\d+$/', $valor))) {
31              return str_replace('.', ',', (string) $valor); // 45.50 → 45,50
32          }
33
34          // 2. Manejo de números enteros (para que no se conviertan en "3,00")
35          if (is_int($valor) || (is_string($valor) && preg_match('/^-?\d+$/', $valor))) {
36              return (string) $valor;
37          }
38
39          // 3. TODO 6 resuelto: Neutralizar fórmulas (incluye espacios o tabuladores al inicio)
40          $texto = (string) $valor;
41          // Expresión regular que busca =, +, -, @, tabulador (\t) o retorno de carro (\r) al inicio
42          if (preg_match('/^[=+\-@\t\r]/', $texto)) {
43              return "'" . $texto;
44          }
45
46          return $texto;
```

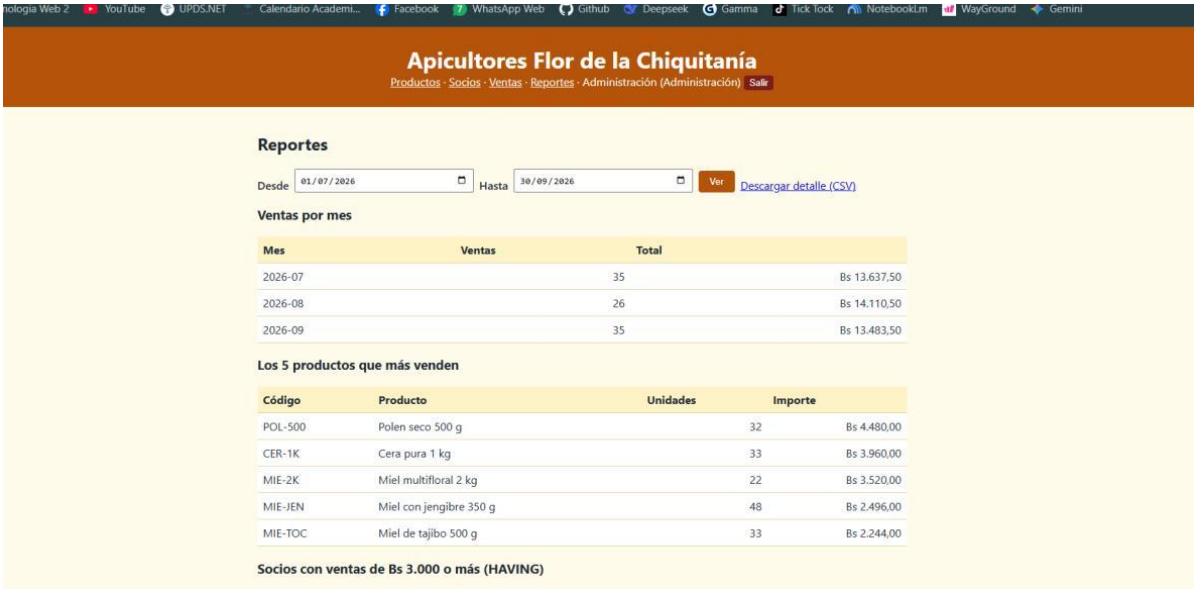
Nota. Fragmento de elaboración propia a partir del código fuente del proyecto: src/Reportes/Csv.php (líneas 13–17 y 27–46).

2.5. Resultados documentados del Laboratorio 11

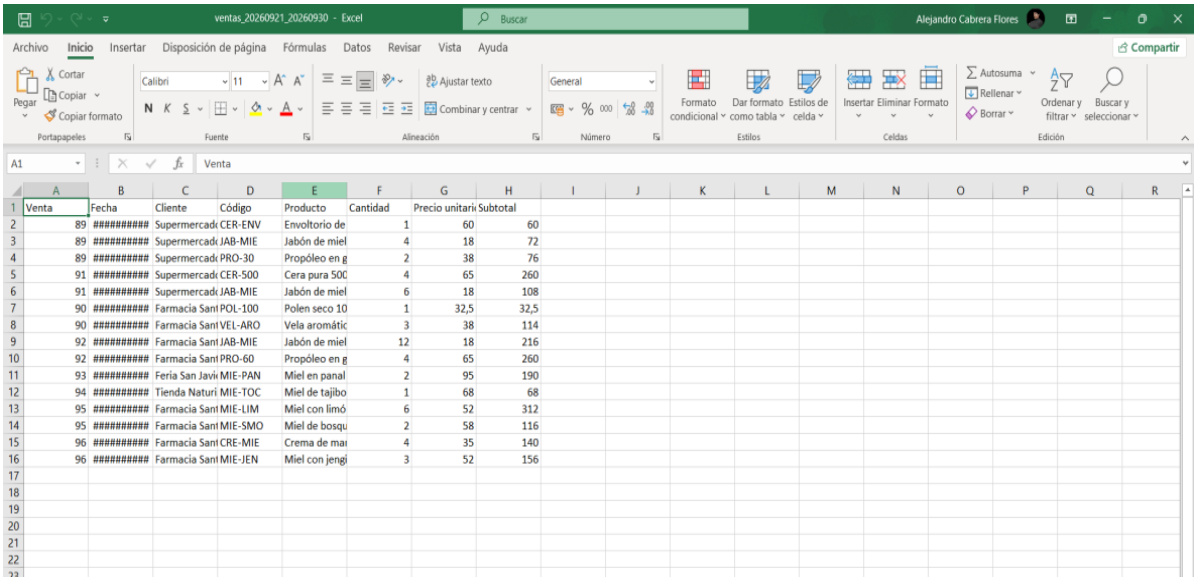
La bitácora del Laboratorio 11 reporta 15 de 15 comprobaciones satisfactorias. Entre los casos registrados están el esquema y las claves foráneas, los reportes mensuales, los cinco productos principales, socios que superan el mínimo de Bs 3.000, productos sin ventas, inclusión del último día, atomicidad de ventas, actualización de stock por acopio, protección CSV, acceso del operador denegado a reportes con HTTP 403 y rechazo de fechas inválidas con HTTP 422 (Salas Tococari, 2026b).

```
PS C:\Laboratorio 11\lab11\inicio> php verificar.php
[OK] Esquema: ventas, venta_detalle (clave compuesta) y acopios con sus claves foráneas
[OK] Reporte por mes = suma independiente en PHP (jul, ago, sep)
[OK] Top 5 productos (JOIN + SUM + ORDER BY + LIMIT) = cálculo independiente
[OK] Socios con Bs 3.000 o más (HAVING): 4 de 8 = cálculo independiente
[OK] Productos sin ventas (LEFT JOIN … IS NULL): CER-BLO, JAL-30, MIE-OR, VIN-MIE
[OK] El período incluye el último día completo (ventas del 30/09 entran con hasta=2026-09-30)
[OK] Transacción: si una línea falla (99 CER-1K), NO se descuenta la otra ni se crea la venta
[OK] Venta correcta: descuenta stock, total 128.00 y guarda el precio unitario del día
[OK] Últimas unidades: vender 3 CER-1K (hay 4) funciona; otra vez 3 → Conflicto y el stock queda en 1
[OK] Acopio: +10 CER-1K sube el stock y registra al socio dueño; cantidad 0 → DatosInvalidos
[OK] Csv::celdaSegura: =, +, - y @ al inicio se neutralizan; decimales con coma
[OK] Operador: registra una venta por el formulario (303) pero /reportes → 403
[OK] Formulario: stock insuficiente → 409 y nada cambia
[OK] Admin: /reportes muestra las 4 tablas; fechas inválidas (2026-02-31, desde > hasta) → 422
[OK] CSV: text/csv + attachment, BOM, ";" y una línea por detalle; el cliente "=HYPERLINK" queda neut
ralizado
```

Evidencia L11-01. Salida de php verificar.php del Laboratorio 11: 15 de 15 comprobaciones.



Evidencia L11-04a. Página de reportes del administrador (período 01/07/2026 a 30/09/2026).



Evidencia L11-04b. Archivo ventas_20260921_20260930.csv abierto en Excel.



Evidencia L11-04c. Error HTTP 422 al ingresar un rango de fechas inválido.

3. Resultados generales

De acuerdo con las bitácoras aportadas, ambos laboratorios alcanzaron el resultado documentado de 15 de 15 comprobaciones. El Laboratorio 10 se orienta a proteger identidad, sesión y permisos; el Laboratorio 11 protege la consistencia de los movimientos y facilita el análisis de la actividad comercial. Las pruebas descritas cubren operaciones correctas e intentos inválidos o no autorizados.

La Tabla 4 resume los criterios principales y las evidencias que deben incorporarse a la entrega final.

Tabla 4

Resumen de resultados y evidencias

Criterio	Resultado documentado	Evidencia a adjuntar
Autenticación y sesiones	L10: 15/15 en bitácora	Verificador y acceso válido/incorrecto
CSRF y XSS	Pruebas de seguridad reportadas	Formulario con token y salida escapada
Roles	Admin, operador y socio diferenciados	Capturas de permisos y denegación HTTP 403
Transacciones	Rollback ante stock insuficiente	Stock y ventas antes/después de prueba
Reportes SQL	Cuatro reportes descritos en bitácora	Página de reportes y tablas
CSV	Protección de fórmulas y formato regional	Archivo abierto en hoja de cálculo

CONCLUSIONES

La separación de permisos por rol reduce el riesgo de que un usuario realice operaciones que no le corresponden, siempre que las restricciones se validen en el servidor y no únicamente en la interfaz. **Alejandro Fabián Cabrera Flores**

El uso de password_hash(), password_verify(), sesiones regeneradas y tokens CSRF aporta controles esenciales para proteger las cuentas de usuario y las operaciones sensibles del sistema. **María Alejandra Suárez O.**

Las transacciones y las actualizaciones condicionales del stock mantienen la coherencia del inventario ante errores o ventas concurrentes, evitando que se registren operaciones incompletas. **Jade Guissel Flores Coria**

Los reportes elaborados con JOIN, GROUP BY, HAVING y LEFT JOIN permiten transformar los datos de ventas e inventario en información útil para la administración de la asociación. **Ariel Salas Tococari**

La exportación CSV también requiere medidas de seguridad, ya que los datos pueden abrirse en programas que interpretan determinados textos como fórmulas. Por ello, es importante proteger el contenido exportado. **Renzo Molina Navia**

RECOMENDACIONES

Ejecutar los verificadores desde las carpetas finales lab10/inicio y lab11/inicio, conservando la salida completa de la consola para respaldar los resultados obtenidos. **Alejandro Fabián Cabrera Flores**

Evitar ejecutar ambos laboratorios simultáneamente si utilizan el mismo nombre de contenedor y puerto. Se recomienda revisar la configuración de Docker Compose y comprobar que MySQL esté disponible antes de iniciar las pruebas. **María Alejandra Suárez O.**

No utilizar docker compose down -v sin realizar previamente un respaldo, porque este comando puede eliminar el volumen de datos de la base de datos. **Jade Guissel Flores Coria**

Evitar incluir contraseñas, cookies de sesión, tokens CSRF u otros datos sensibles en las capturas que se incorporen al informe o se publiquen en el repositorio. **Ariel Salas Tococari**

Verificar que las pruebas funcionales del sistema se ejecuten correctamente, comprobando que los productos se registren y actualicen de manera adecuada, que las ventas descuenten el stock correspondiente y que los errores no generen cambios parciales en la base de datos. **Renzo Molina Navia**



REFERENCIAS

American Psychological Association. (s. f.). Tables and figures. APA Style. https://apastyle.apa.org/style-grammar-guidelines/tables-figures

Oracle. (s. f.). START TRANSACTION, COMMIT, and ROLLBACK statements. En MySQL 8.4 Reference Manual. https://dev.mysql.com/doc/refman/8.4/en/commit.html

OWASP Foundation. (s. f.-a). Cross-site request forgery prevention cheat sheet. OWASP Cheat Sheet Series. https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html

OWASP Foundation. (s. f.-b). CSV injection. OWASP. https://owasp.org/www-community/attacks/CSV_Injection

PHP Documentation Group. (s. f.). password_hash. En PHP manual. https://www.php.net/manual/es/function.password-hash.php

Salas Tococari. (2026). Bitácora de IA del Laboratorio 10: Autenticación y seguridad.

Alejandro Fabián Cabrera Flores. (2026). Bitácora de IA del Laboratorio 11: Transacciones, reportes y CSV.

Tecnología Web II. (2026). Guía integral: Actividad 3, laboratorios 10 y 11: Sistema de la Asociación de Apicultores - Material de curso.

Tecnología Web II. (2026). Paquete de laboratorios 06–11 - Archivos de práctica proporcionados en clase.